

Tinker Tailor LLM Spy

Reconstructing 'Deleted' Chats & Hijacking Sessions from Chromium LevelDB Caches

Target Venue: Black Hat Europe Briefings

Authors: Dr. Sapna V M, Prajwal Chowdary, Prasad H B

Institution: ISFCR Lab, Dept of Computer Science & Engineering, PES University, Bangalore, India

Official Repository: <https://github.com/prajwalchowdary2/tinker-tailor-llm-spy-bheu>

I. The Ephemeral AI Fallacy & LSM-Tree Remanence

- **Cloud Deletion vs Local Persistence:** Clicking 'Delete Chat' updates cloud servers, but Chromium (Chrome, Edge, Brave) and Electron desktop apps retain local telemetry in LevelDB storage.
- **Append-Only LSM Engine:** Writes are appended sequentially to Write-Ahead Logs (.log). 'Deletions' are mere index updates or tombstones; serialized data blocks linger intact until background compaction.
- **Empirical Finding:** 506 text artifacts recovered across 23 profiles; **70.8% (358 artifacts) were already deleted from the web UI.** One artifact persisted for 83 days.

II. Reverse Engineering V8 Serialization & Framing

- **Varint Decoding:** Protocol Buffer style 7-bit variable-length integer parsing for offsets and string lengths.
- **Tag Identification:** Parsing OneByteString (0x22 ASCII) and TwoByteString (0x63 UTF-16LE byte-length tagged strings).
- **Smi-Shifted Array Keys:** Small Integer keys encoded via left-shift (encoded = actual << 1). Odd actual indices = User Prompts; Even actual indices = Assistant Replies.
- **Nesting Depth Tracking:** Dynamic tracking of object/array depth (0x6f/0x61) prevents premature message truncation on inner end tags (0x7b).

III. New Endpoint Vulnerability Discoveries

- **Claude Pre-Submission Keystroke Caching:** TipTap editor state serializes in-flight keystrokes to disk in real-time *before* the user clicks 'Send'. 148 draft fragments recovered.
- **Plaintext Document Blobs (.indexeddb.blob/):** Uploaded 10MB PDF documents and proprietary code files stored completely unencrypted, surviving conversation deletion indefinitely.
- **ECDSA Private Keys in ChatGPT Desktop:** com.openai.atlas stores raw WebRTC ECDSA private keys (-----BEGIN PRIVATE KEY-----) in LevelDB logs alongside chat transcripts.
- **Google Gemini Extension (glic):** Stores conversation keys (BARD_EMBED_CHAT_STORAGE_KEY) in Local Storage LevelDB.

IV. Live Carving Engine & Shadow AI DLP

- **Lock-Free Live Carving:** Read-only binary stream parsing bypasses exclusive LevelDB process locks without disrupting active browser sessions.
- **Real-Time Shadow AI DLP:** On-the-fly extraction and regex classification of leaked AWS access keys, OpenAI API tokens, Slack tokens, JWTs, and PII.
- **HMAC-SHA256 Chain of Custody:** Canonical evidence payload signing, verified client-side using Web Cryptography API (`window.crypto.subtle.verify`).
- **Sub-150ms Performance:** Full multi-profile scan completes in 147–163 ms, executing before endpoint monitor latency windows.

V. Defensive Mitigations & Tool Release

- **OS Storage Encryption:** Enforce full-disk encryption (FileVault / BitLocker) and extend DPAPI protections to IndexedDB storage directories.
- **Session Purge Policies:** Configure enterprise GPO/MDM browser policies to purge IndexedDB cache and blob files on browser termination.
- **Endpoint Telemetry Rules:** Deploy EDR behavioral rules monitoring unprivileged access to Chromium IndexedDB directories.

- **Complete Open-Source Release:**

<https://github.com/prajwalchowdary2/tinker-tailor-llm-spy-bheu>